

Essentials of Cyber Security (CSE336)

Module – 2

(Cyber Law & Policy)

Cybersecurity Management Concepts

What is Cybersecurity Management?

- Cybersecurity management is the **process of planning, controlling, and monitoring security policies and practices** to protect an organization's **data, systems, and networks** from cyber threats.

A threat in cybersecurity is anything that can cause harm to your computer, device, data, or online accounts.

- It's not just about installing antivirus or firewalls — it's about **managing people, processes, and technology** together.

Example - Imagine you are the **security manager of a bank**. Your job is to ensure:

- Customers' money transfer apps are secure,
- Data is not tampered with,
- Systems work 24/7 without downtime.
- This is **cybersecurity management** in action.

Key Concepts in Cybersecurity Management

1. CIA Triad (Core Principle)

- **Confidentiality** – Protecting information from unauthorized access.

What it really means - Only the **right people/processes** can see specific data.

Example: Encrypting customer passwords.

- **Integrity** – Ensuring information is accurate and not altered.

What it really means - If someone tampers with data, we can **detect** it (and ideally **prevent** it).

Example: A bank transaction: Alice transfers ₹50 to Bob. If a hacker tries to change it to ₹50,000, the **database integrity checks** and **transaction logs** detect the tampering.

- **Availability** - Systems and data are **usable when needed**, at the required performance level.

What it really means - Plan for **faults, spikes, disasters, and attacks** so service stays up—or recovers fast.

Example: Using backup servers so online banking never goes down.

Key Concepts in Cybersecurity Management

2. Risk Management

- Cybersecurity is about **reducing risks to an acceptable level**.

Steps: Identify risks → Analyze → Apply controls → Monitor.

Example: If college Wi-Fi is open, risk = hacking. Control = enable WPA2 security + strong passwords.

3. Defense in Depth (Layered Security)

- Uses several lines of defense so that if one layer fails, others still protect the assets
- Don't rely on **one security control**. Use multiple layers.

Example: Locking your room → Confidentiality.
 CCTV camera → Integrity (evidence if tampered).
 Hostel warden → Availability (ensures services continue).

Key Concepts in Cybersecurity Management

4. Least Privilege Principle

- Users and systems are provided the minimum level of access needed to perform tasks, limiting the impact of a breach.
- Users should get **minimum access** required for their job.

Example:

- A student assistant in the library should only access the book database, not exam records.
- In companies, HR can see employee salaries but not the company's source code.

5. Accountability and Auditing

- Every user action must be **logged and monitored**.
- Helps in tracing who did what in case of a cyberattack.

Example: If someone deletes important files, logs help identify the culprit.

Key Concepts in Cybersecurity Management

6. Compliance and Legal Requirements

- Organizations must follow **laws and standards** (e.g. IT Act 2000 in India).

Example: Hospitals must secure patient data.

7. Incident Response & Business Continuity

- Security management also means preparing for the **worst-case scenario**.
 - **Incident Response:** Steps to detect, contain, and recover from an attack.
 - **Business Continuity:** Backup plans to keep services running.

Example: If a ransomware attack locks student records, university should restore backups quickly so classes aren't disrupted.

Security Governance

- Security Governance is like the **“rules and directions”** for managing cybersecurity in an organization.
- Just like a school has rules (discipline, uniforms, attendance), organizations also have **policies and frameworks** to keep their data and systems safe.
- Governance ensures that **cybersecurity is not random**, but properly planned, managed, and aligned with the goals of the company.

“Security Governance refers to the set of responsibilities and practices exercised by the top management to provide strategic direction, ensure objectives are achieved, manage risk, and verify that resources are used responsibly for information security.”

➤ **In Simple Words:**

It is how leaders make sure cybersecurity is working properly and supports the business.

Security Governance

Why Security Governance is Important?

- Cyber attacks are increasing → Without governance, security will be weak.
- Ensures **accountability** → Who is responsible for what?

“Accountability means being responsible and answerable for your actions, decisions, or duties.”

- Aligns **security with business goals**.

Example: A bank wants fast online services but must also keep customer data safe.

- Helps in following **laws and regulations**.

Key Elements of Security Governance

1. Leadership & Accountability

- Management is responsible for making sure security is taken seriously.

Example: Appointing a CISO (Chief Information Security Officer).

2. Security Policies

- Written rules about what employees can and cannot do.

Example: “Do not share your password.”

3. Risk Management

- Identifying threats and reducing them.

Example: If employees use USB drives, risk = malware → Control = block USB access.

Key Elements of Security Governance

4. Compliance with Laws & Standards

- Following government laws (e.g., IT Act 2000 in India, GDPR in EU).
- Using standards like **ISO 27001, NIST, COBIT**.

5. Security Awareness & Training

- Teaching employees about phishing, password protection, social engineering.

Example: Conducting mock phishing email tests.

6. Monitoring & Continuous Improvement

- Regular audits, security reviews, and updating policies as threats change.

• Difference Between IT Governance & Security Governance

- **IT Governance:** Overall management of IT resources. IT Governance:
 - Deciding which new software to buy.
- **Security Governance:** Focuses only on protecting information and systems.
 - Ensuring the software has proper encryption.

Management Models

- A **management model** describes the **approach an organization uses to create, enforce, and monitor cybersecurity policies and practices.**
- The model defines **who makes decisions, how authority is distributed, and how responsibilities are managed.**

a) Centralized Model-

- All **cybersecurity decisions, policies, and controls are managed by a central authority**, usually the **IT Security Department** under the leadership of the CISO.
- All decisions about security are made by a central authority (like a Chief Information Security Officer - CISO).
- **Policies and controls are uniform across the organization.**

Example: A bank's head office decides password policies for all its branches.

Management Models

Characteristics:

- Uniform security policies across the entire organization.
- Centralized monitoring, auditing, and reporting.
- Single point of decision-making.

Advantages:

- Easier to maintain consistent security.
- Strong control over data protection and compliance.
- Faster to implement large-scale security policies.

Disadvantages:

- Less flexibility for individual departments.
- Central team may become overloaded with responsibilities.

Management Models

b) Decentralized Model-

- In a decentralized model, security authority and responsibility are distributed to departments or business units, which choose controls, workflows, and priorities tailored to their missions and risks, enabling faster local decisions and alignment with unique environments.
- **Each department or business unit manages its own security.**

Example: In a university, each department sets its own rules for securing lab computers.

Characteristics:

- Autonomy for departments.
- Security solutions may vary between units.

Management Models

Advantages:

- Flexibility to adapt security controls to departmental needs.
- Encourages innovation in security solutions.

Disadvantages:

- Inconsistency in security policies.
- Harder to monitor compliance across the organization.
- Risk of weak points in less-aware departments.

Management Models

c) Hybrid Model-

- A hybrid model combines a central authority for strategy, policies, and platform services with distributed teams that implement and tailor controls to their unique missions.
- It aims to achieve uniform risk standards and visibility while preserving speed and context-aware decision-making close to the work.
- **A combination of centralized and decentralized approaches.** The central authority defines the **core policies**, while departments are free to **customize certain aspects**.

Example: A company requires all employees to use multi-factor authentication (MFA) (central policy), but departments may choose whether to use fingerprint scanners, smart cards, or mobile authentication apps.

Management Models

Advantages:

- Balances uniformity with flexibility.
- Core compliance is ensured, while specific needs are addressed.

Disadvantages:

- Requires careful coordination.
- Risk of miscommunication between central and departmental teams.

Management Models

Other Models-

1. Top-Down Model:

- Security policies are created by senior management and flow downward.
Example: CEO mandates mandatory use of VPN for remote workers.

2. Bottom-Up Model:

- Security needs arise from employees or technical staff and are later approved by management.
Example: System admins propose implementing intrusion detection systems, and management approves it.

3. Security Governance Model:

- Ensures security is aligned with business goals, laws, and industry standards.
Example: An e-commerce company aligning its data protection policies with GDPR requirements.

Roles in Cybersecurity Management

1. Top Management (Board of Directors, CEO, CIO)

- Provide **vision, mission, and policies** for cybersecurity.
- Allocate **budget and resources**.
- Ensure compliance with **laws and regulations**.

Example: A CEO approves an investment in Artificial Intelligence-based threat detection tools.

2. Chief Information Security Officer (CISO)

- The **head of cybersecurity** in an organization.
- Responsible for **strategy, governance, policies, and risk management**.
- Oversees **incident response** and **business continuity planning**.

Example: The CISO decides how to deal with a ransomware attack: whether to restore from backup or negotiate with attackers.

Roles in Cybersecurity Management

3. IT Security Managers

- **Implement the security strategy** created by the CISO.
- Manage teams that handle **firewalls, anti-virus, access controls, and patching**.
- Ensure employees follow security policies.

Example: An IT Manager ensures all company laptops are encrypted and updated regularly.

4. System and Network Administrators

- Handle the **technical side** of security.
- Configure **servers, routers, firewalls, and user accounts**.
- Monitor system logs for unusual activities.

Example: A network admin blocks unauthorized IP addresses trying to access the network.

Roles in Cybersecurity Management

5. Security Analysts / Incident Response Team

- Continuously monitor systems.
- Detect, investigate, and respond to threats.

Example: A security analyst notices abnormal traffic at 2 AM and blocks a potential intrusion.

6. End Users (Employees, Students, Staff)

- **Follow security guidelines** (strong passwords, not clicking phishing links, reporting suspicious emails).

Example: A student reports receiving a suspicious link asking for login details.

Functions of Cybersecurity Management

Cybersecurity management involves **five core functions**, most clearly explained in the **NIST Cybersecurity Framework**.

These functions describe a **continuous cycle of protection**.

1. Identify-

- Understand what needs to be protected.
- Includes **asset inventory, risk assessment, and threat analysis**.

Example: Identifying that customer data, employee payroll system, and product designs are critical assets.

2. Protect-

- Develop safeguards to secure systems and data.
- Includes **firewalls, encryption, access control, and training employees**.

Example: Protecting data using end-to-end encryption and training employees not to use weak passwords.

Functions of Cybersecurity Management

3. Detect-

- Monitor systems to find cyber incidents quickly.
- Includes **intrusion detection systems, security monitoring, and alerts.**

Example: An intrusion detection system alerts about multiple failed login attempts.

4. Respond-

- Take immediate action when an incident occurs.
- Includes **incident response plans, communication, and containment.**

Example: When a worm spreads through the network, the affected computers are disconnected immediately to prevent further infection.

Functions of Cybersecurity Management

5. Recover-

- Restore systems and services after an incident.
- Includes **data backups, disaster recovery plans, and system rebuilding**.

Example: After a ransomware attack, the company restores files from backup instead of paying the ransom.

Short Re-cap:

- **Management Models** define how cybersecurity decisions are structured (centralized, decentralized, hybrid).
- **Roles** define responsibilities of management, technical staff, and users.
- **Functions** describe step-by-step tasks to protect, detect, respond, and recover from cyber threats.
- Cybersecurity is **not just technical – it is also about people, processes, and management**.

Enterprise Roles and Structures

- Every organization (enterprise) has a **structure** – meaning, how people are organized, who reports to whom, and who makes decisions.
- Enterprises today depend heavily on technology and digital assets. This makes them vulnerable to cyber threats such as data breaches, ransomware, phishing, insider attacks, and system failures. To safeguard against these risks, organizations establish **enterprise security structures** and assign **specific roles and responsibilities**.
- An enterprise's **security structure** defines how cybersecurity is organized within the company, and the **roles** explain who is responsible for what tasks. Together, they ensure accountability, efficiency, and compliance with laws.

Enterprise Security Structures

1. Centralized Security Structure

- A single, centralized cybersecurity team manages all policies and controls.
- Security decisions are consistent and uniform.

Advantages: Strong control, compliance-friendly.

Disadvantages: Less flexible, slower response in specialized cases.

Example: A national bank with a head office managing firewalls, encryption, and incident response for all branches.

2. Decentralized Security Structure

- Each department, division, or business unit manages its own security.
- Policies may differ across units.

Advantages: Flexibility, tailored security solutions.

Disadvantages: Inconsistency, difficult to monitor.

Example: A multinational company where regional offices follow their own cybersecurity measures.

Enterprise Security Structures

3. Hybrid Security Structure

- A **mix of centralized and decentralized** models.
- The core policies are defined centrally, but departments can add controls as needed.

Advantages: Balanced, adaptable, consistent core framework.

Disadvantages: Coordination challenges, risk of overlap.

Example: A university mandates all users to have strong passwords (central), but departments can implement biometric authentication if required.

Enterprise Security Roles

1. Board of Directors / Executive Leadership

- Approves cybersecurity budgets and policies.
- Ensures security aligns with business strategy.
- Maintains accountability to shareholders and regulators.

2. Chief Executive Officer (CEO)

- Holds ultimate responsibility for business security.
- Approves investments in security infrastructure.
- Promotes a culture of security awareness across the enterprise.

Enterprise Security Roles

3. Chief Information Officer (CIO)

- Responsible for the overall IT infrastructure.
- Works with the CISO to integrate IT and security needs.
- Ensures technological decisions do not compromise security.

4. Chief Information Security Officer (CISO)

- Head of the enterprise's cybersecurity function.
- Defines security strategy, governance policies, and compliance requirements.
- Oversees incident response, risk management, and awareness programs.

Enterprise Security Roles

5. IT Security Managers

- Convert security strategies into **day-to-day operational practices**.
- Supervise system administrators, analysts, and engineers.
- Monitor compliance with internal and external security standards.

6. System and Network Administrators

- Configure and maintain secure networks, servers, and user accounts.
- Implement access controls, firewalls, and patch management.
- Monitor logs and identify unusual activity.

Enterprise Security Roles

7. Security Analysts (Blue Team)

- Monitor systems for threats using tools like SIEM (Security Information and Event Management).
- Detect intrusions, investigate alerts, and escalate issues.
- Act as the “first responders” to cyber incidents.

8. Security Engineers / Architects

- Design, develop, and maintain security infrastructure.
- Build solutions such as Zero Trust models, encryption frameworks, and secure network architectures.

9. Incident Response Team (CSIRT)

- Specialized group focused on handling cyber incidents.
- Contain, mitigate, and recover from attacks.
- Ensure business continuity during crises.

Enterprise Security Roles

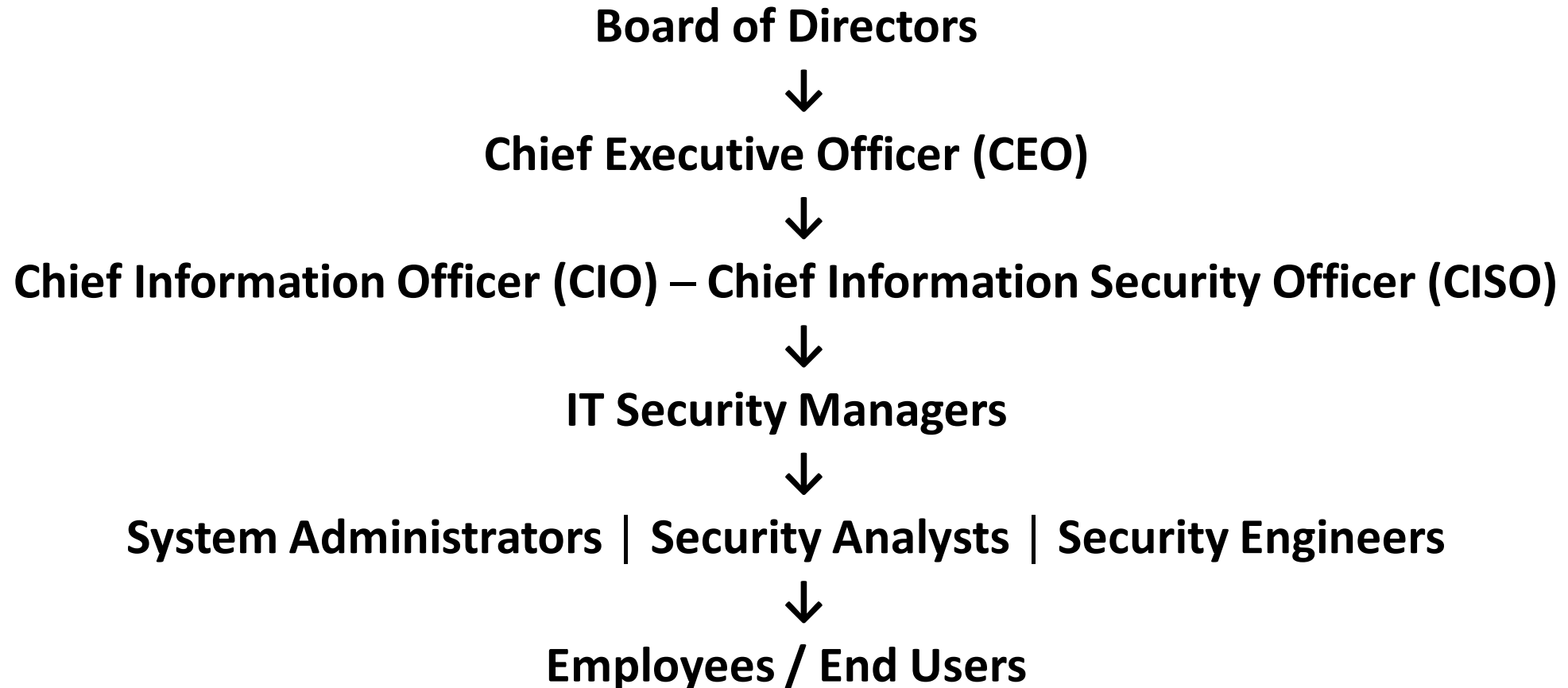
10. End Users (Employees, Students, Staff)

- Every employee contributes to enterprise security.
- Their role includes following security policies, reporting suspicious activities, and avoiding risky behaviour.

11. External Stakeholders

- **Auditors:** Assess compliance with standards (ISO 27001, GDPR).
- **Regulators:** Enforce cybersecurity laws.
- **Third-party vendors:** Provide security products, consulting, and services.

Typical Enterprise Cybersecurity Structure



Information Security Roles and Positions

- In any organization, **information security** is not the responsibility of one person alone. It requires a **team of professionals** at different levels, each with specific responsibilities and **authority**.

Roles and positions ensures:

- Accountability
- Proper risk management
- Faster response to incidents
- Compliance with laws and standards

Information Security Roles and Positions

1. Board of Directors / Senior Executives

- Provide overall **governance and direction** for information security.
- Ensure that cybersecurity is part of enterprise risk management.

Example: Approving funds for data protection technologies.

2. Chief Information Security Officer (CISO)

- The **highest-ranking security officer**.
- Develops and manages the enterprise-wide security strategy.
- **Responsibilities:** Policy development, Risk management, Incident response planning, Compliance with legal requirements

Example: Designing policies to protect customer data under GDPR.

Information Security Roles and Positions

3. Chief Information Officer (CIO)

- Responsible for overall **IT infrastructure**.
- Works with CISO to ensure IT systems are both functional and secure.

Example: Deciding cloud migration strategies with built-in security.

4. Security Managers

- Supervise **day-to-day security operations**.
- Implement security strategies defined by the CISO.
- Lead teams of administrators, analysts, and engineers.

Example: Ensuring antivirus and firewall policies are enforced across the enterprise.

Information Security Roles and Positions

5. Information Security Officers

- Often mid-level officers reporting to security managers or the CISO.
- Act as **liaisons between management and technical staff**.
- Conduct audits, training sessions, and policy enforcement.

Example: Checking whether employees follow password policies.

6. Security Administrators

- Technical staff responsible for implementing and maintaining security controls.
- Manage firewalls, access control systems, servers, and patching.

Example: Configuring multi-factor authentication (MFA) for employees.

Information Security Roles and Positions

7. Security Analysts

- Monitor systems for threats, analyze logs, and detect suspicious activity.
- Work in **Security Operations Centers (SOC)**.

Example: Detecting unusual traffic at midnight and escalating an alert.

8. Security Engineers / Security Architects

- **Design and build secure systems and networks.**
- Develop encryption frameworks, authentication mechanisms, and network defense strategies.

Example: Designing a zero-trust network architecture for a new data center.

Information Security Roles and Positions

9. Incident Response Team (CSIRT)

- Specialized professionals who respond during cyber incidents.
- **Responsibilities:** Containment of attack, Root cause analysis, Recovery planning

Example: Isolating infected machines during a ransomware outbreak.

10. Data Protection Officer (DPO)

- Position introduced in laws like **GDPR**.
- Ensures the company follows **data privacy regulations**.

Example: Ensuring customer data is stored and processed legally.

Strategic Planning and Security Strategy

- In cybersecurity, **technology alone cannot protect an organization.** What matters is a **planned and structured approach** that aligns with the organization's **business goals**.
- **Strategic Planning** = Long-term planning to achieve business objectives.
- **Security Strategy** = The **blueprint** for protecting information assets while supporting business operations.

What is Strategic Planning?

- Strategic planning in cybersecurity is the process of:
- **Identifying organizational goals** (e.g., secure online banking, safe patient records).
- **Analyzing risks and threats** (hackers, malware, insider threats).
- **Designing long-term security initiatives** to reduce risks.
- **Allocating resources** (budget, tools, staff).
- **Evaluating progress** and updating plans regularly.

Strategic Planning and Security Strategy

What is a Security Strategy?

- A **security strategy** is a **formal plan** that describes:
- How the organization will **protect its digital assets**.
- How **policies, technologies, and people** work together.
- How security efforts support **business goals**.

It covers:

- Governance
- Risk management
- Security controls (technical, physical, administrative)
- Monitoring and response
- Compliance with laws

Strategic Planning and Security Strategy

Components of a Security Strategy:

1. Risk Assessment

- Identify critical assets (customer data, financial records, intellectual property).
- Assess possible threats (hackers, phishing, ransomware, insider misuse).
- Measure risk in terms of **impact and likelihood**.

2. Security Policy Framework

- Develop policies like:
 - Acceptable Use Policy (AUP)
 - Password Policy
 - Data Classification Policy
- Ensure all employees know **what is allowed and what is not**.

Strategic Planning and Security Strategy

3. Security Controls

- **Administrative:** Policies, training, incident response plans.
- **Technical:** Firewalls, encryption, intrusion detection, MFA.
- **Physical:** CCTV, access cards, biometric locks.

4. Incident Response and Business Continuity

- Define steps for detecting, responding, and recovering from cyber incidents.
- Disaster Recovery (DR) and Business Continuity Plans (BCP) must be integrated.

University Example:

Strategic Goal: Provide online education globally.

Security Strategy: Deploy cloud security, protect student data, monitor plagiarism.

Strategic Planning and Security Strategy

5. Incident Response and Business Continuity

- Define steps for detecting, responding, and recovering from cyber incidents.
- Disaster Recovery (DR) and Business Continuity Plans (BCP) must be integrated.

6. Continuous Monitoring and Improvement

- Cybersecurity is **not one-time**.
- Regular audits, penetration testing, and security awareness training.
- Updating policies as threats evolve.

Bank Example:

Strategic Goal: Increase digital banking services.

Security Strategy: Implement MFA, secure mobile apps, continuous fraud monitoring.

Strategic Planning Process in Security

- **Define Security Vision** – “What do we want to achieve?”
(e.g., Protect customer trust in online banking).
- **Understand Business Goals** – Align with corporate mission.
(e.g., Secure e-commerce platform for global customers).
- **Conduct Risk Assessment** – Identify threats, vulnerabilities, impacts.
- **Develop Security Roadmap** – Policies, tools, staff training.
- **Allocate Resources** – Budget, skilled workforce, technologies.
- **Implement Security Programs** – Deploy controls, awareness sessions.
- **Measure & Review** – Use KPIs like number of incidents, patching speed.
- **Continuous Improvement** – Adjust according to new threats.

Information Security Standards & Laws

Information Security Standards

- These are **guidelines and best practices** created by international organizations.
- They tell companies *how* to protect data.

Example: ISO 27001 is a standard that teaches how to manage and secure information.

Information Security Laws

- These are **legal rules made by governments**.
- Companies *must* follow them, otherwise they face **penalties, fines, or even jail**.

Example: GDPR (in Europe) and IT Act 2000 (in India).

Information Security Standards & Laws

Why do we need standards & laws?

- To protect data from misuse, theft, and cybercrime.
- To ensure organizations follow best practices.
- To give legal consequences if rules are broken.

Example: If a bank leaks customer data → it must follow security standards & laws or face penalties.

“Standards are **rules and frameworks** created by international organizations to help companies secure information.”

Information Security Standards & Laws

Common Standards

1. ISO/IEC 27001

- Global standard for **Information Security Management System (ISMS)**.
- Focus: Risk management, policies, controls.

Example: A hospital using ISO 27001 ensures patient records are protected.

2. NIST Cybersecurity Framework (USA)

- Defines **Identify → Protect → Detect → Respond → Recover**.
- Helps companies reduce risks and recover from attacks.

3. COBIT (Control Objectives for Information & Related Technologies)

- Focuses on IT governance & aligning security with business goals.

Information Security Standards & Laws

4. PCI-DSS (Payment Card Industry – Data Security Standard)

- Protects **credit card transactions**.

Example: Online shopping sites must follow PCI-DSS to secure cardholder data.

5. GDPR Security Standards (EU)

- Requires organizations to protect personal data & privacy of EU citizens.

“Laws are **legal requirements** enforced by governments. Breaking them can lead to **penalties, fines, or imprisonment.**”

Information Security Standards & Laws

Major Laws Worldwide

1. IT Act 2000 (India)

- Covers cybercrime, hacking, identity theft, and e-signatures.

Example: Sending phishing emails → punishable under IT Act.

2. General Data Protection Regulation (GDPR – EU)

- Protects personal data & privacy of EU residents.
- Heavy fines for violations (up to 4% of annual revenue).

3. HIPAA (Health Insurance Portability & Accountability Act – USA)

- Protects patient health information.

Example: Hospitals must secure medical records.

Information Security Standards & Laws

4. CCPA (California Consumer Privacy Act – USA)

- Gives California residents control over their personal data.

5. SOX (Sarbanes-Oxley Act – USA)

- Ensures financial data integrity and prevents fraud.

Aspect	Standards	Laws
Nature	Voluntary (best practice)	Mandatory (legal requirement)
Purpose	Improve security posture	Protect citizens & punish offenders
Examples	ISO 27001, NIST, PCI-DSS	IT Act 2000, GDPR, HIPAA
Penalty for Non-Compliance	Lose certifications, reputational damage	Fines, lawsuits, imprisonment

Information Security Standards - ISO

What is ISO?

ISO = International Organization for Standardization

- It is an **independent, non-governmental international body**.
- Headquartered in **Geneva, Switzerland**.
- Established in **1947**.
- Members from **160+ countries**.
- ISO creates **standards** to ensure **quality, safety, security, and efficiency** across industries.
- ISO works with the **IEC (International Electrotechnical Commission)** to publish **ISO/IEC standards** for cybersecurity and information protection.

Information Security Standards - ISO

The most important standard for cybersecurity is:

ISO/IEC 27001

- It is the **global standard for Information Security Management System (ISMS)**.
- Helps organizations manage risks related to data (like hacking, data theft, and insider threats).
- Provides a **framework of policies and controls** to keep information safe.

Example:

- A **bank** using ISO/IEC 27001 ensures customer account details are protected.
- A **hospital** using ISO standards secures patient records.
- An **IT company** using ISO ensures its clients' data is not leaked.

Information Security Standards - ISO

Standard	Focus Area	Example Use
ISO/IEC 27001	Information Security Management (ISMS)	Bank securing accounts
ISO/IEC 27002	Security Controls (practical steps)	IT company enforcing password policies
ISO/IEC 27005	Risk Management	Hospital protecting patient data
ISO/IEC 27017	Cloud Security	AWS/Google Cloud security
ISO/IEC 27018	Data Privacy in Cloud	Protecting files in Google Drive
ISO/IEC 27701	Privacy & GDPR compliance	E-commerce handling EU data

IT Act (Information Technology Act, 2000 India)

Purpose: To give **legal recognition** to electronic records, e-signatures, and regulate cyber activities.

Covers:

- Cybercrimes (hacking, identity theft, cyber fraud)
- Data protection
- Digital signatures & electronic contracts
- Legal framework for e-commerce

Why was IT Act introduced?

- Before 2000, Indian laws did not cover online activities.
- With the growth of **internet, e-commerce, and online banking**, a new law was needed.
- The Act gives **legal recognition** to digital transactions and punishes cybercrimes.

IT Act

Key Features of IT Act:

- **Legal recognition of digital signatures & e-signatures**
 - Contracts signed electronically are valid.
- **Legal recognition of electronic records**
 - Emails, electronic files, and e-documents are valid in court.
- **Cybercrime provisions**
 - Defines punishments for hacking, identity theft, cyber fraud, etc.
- **Data privacy & security**
 - Protects sensitive personal data.
- **E-Governance support**
 - Allows government services to be delivered electronically.

Important Sections of IT Act

Section 43 – Penalty for unauthorized access, data theft, spreading viruses.

Section 65 – Tampering with computer source code.

Section 66 – Hacking.

Section 66C – Identity theft (stealing password, digital signature).

Section 66D – Cheating by impersonation (phishing, fraud).

Section 67 – Publishing obscene content online.

Section 72 – Breach of confidentiality and privacy.

Example:

- If a hacker steals ATM card details → punished under **Section 66C** (identity theft).
- If an employee leaks private customer data → punished under **Section 72** (privacy breach).
- If someone spreads viruses in a system → punished under **Section 43**.

Copyright Act

Law that protects the rights of creators over their original work.

“The Copyright Act (India, 1957) is a law that protects the rights of creators over their original works like books, music, films, software, and art. It prevents unauthorized copying, distribution, or misuse, while allowing limited fair use for education and research.”

☐ In India, it is called the **Copyright Act, 1957** (with amendments, latest in 2012).

☐ It gives **exclusive rights** to creators of literary, artistic, musical, dramatic, and software works.

Purpose of the Copyright Act:

- To **protect creators** from unauthorized copying or misuse.
- To encourage **innovation, creativity, and knowledge sharing**.
- To ensure creators can **earn money/royalties** from their work.

Key Features of the Copyright Act

1. Protected Works

- Books, articles, music, movies, paintings, software, databases, websites, etc.

2. Exclusive Rights of the creator

- Reproduce the work.
- Distribute copies.
- Translate or adapt the work.
- Display or perform publicly.

3. Duration of Copyright

- **Author's lifetime + 60 years** after death (for literary, musical, artistic works).
- **60 years** from publication for sound recordings, films, and government works.

Copyright Act

4. Computer Programs (Software)

- Treated as “literary work.”
- Copying or pirating software without license is a **copyright violation**.

5. Fair Use / Exceptions

- Limited use for **education, research, criticism, news reporting** is allowed.

Cybersecurity Connection

- Copying software, movies, or music without permission = **software piracy**.
- Hosting or distributing pirated software = punishable under **Copyright Act**.

Example: Torrent sites offering cracked versions of Windows or MS Office.

Copyright Act

Example:

- A student downloads a **pirated movie** → illegal under Copyright Act.
- A company uses **unlicensed software** → can face penalties and lawsuits.
- A writer's novel copied and sold without permission → violation of copyright.

Patent Law

What is Patent Law?

- A **patent** is an exclusive right granted to an inventor for a new invention.
- **Patent Law** protects inventors from others **making, using, selling, or distributing** their invention without permission.
- In India, this is governed by the **Patents Act, 1970** (amended in 2005 to comply with WTO–TRIPS).

“Patent Law (India: Patents Act, 1970) protects inventors by granting them exclusive rights over their inventions for 20 years, preventing unauthorized use, selling, or copying. It encourages innovation while balancing public interest.”

Purpose of Patent Law:

- To **encourage innovation** by rewarding inventors.
- To give inventors a **time-limited monopoly** (in India = 20 years).
- To ensure inventions are eventually **shared with society** after patent expiry.

Key Features of Patent Law

1. Patentable Inventions

- New and novel inventions.
- Useful (industrial application).
- Non-obvious (not already known).
- Examples: Machines, medicines, computer hardware, industrial processes.

2. Non-Patentable Inventions

- Abstract ideas, laws of nature, mathematical methods.
- Discoveries (e.g., scientific principles).
- Software *per se* (but software with hardware/process application may be patentable).

3. Patent Duration

- Valid for **20 years** from the date of filing.

Key Features of Patent Law

4. Rights of Patent Holder

- Right to stop others from making, selling, or using the invention.
- Right to license the patent to others for profit.

5. Compulsory Licensing

- Government can allow others to use the invention **without patent holder's consent** in cases of public interest (e.g., life-saving medicines).

Example:

- If a company invents a **new type of battery**, it can patent it → no other company can make/sell it without permission.
- A **pharmaceutical company** patents a new drug → valid for 20 years.
- A **software-hardware combo** for a unique fingerprint authentication method could be patented.

IPR (Intellectual Property Rights)

- Intellectual Property = **creations of the human mind** (inventions, designs, books, music, software, logos, etc.).
- IPR gives **legal rights** to the creator/inventor to protect and control the use of their creation.
- **IPR protects ideas and creativity, just like property rights protect physical things.**

“Intellectual Property Rights (IPR) are legal rights that protect creations of the mind such as inventions, books, music, software, logos, and designs, giving the creator exclusive control over their use for a certain period.”

Objectives of IPR:

- Encourage **innovation and creativity**.
- Give **exclusive rights** to creators for a certain time.
- Prevent **unauthorized use** (copying, selling, distributing).
- Promote **economic growth** through knowledge-based industries.

Types of IPR

1. Copyright

- Protects: Books, music, films, software, artwork.
- Duration: Author's life + 60 years.

Example: Pirated movies violate copyright.

2. Patent

- Protects: New inventions, products, processes.
- Duration: 20 years.

Example: A new drug patented by a pharma company.

3. Trademark

- Protects: Logos, brand names, slogans.
- Duration: 10 years (renewable).

Example: Apple logo, Nike's "Just Do It."

4. Designs

- Protects: Shape, appearance, or design of products.
- Duration: 10 years (extendable).

Example: The unique design of a Coca-Cola bottle.

Types of IPR

5. Geographical Indications (GI)

- Protects: Products linked to a place.
- Example: Darjeeling Tea, Banarasi Saree.

6. Trade Secrets

- Protects: Confidential business information (formulas, recipes, algorithms).
- Example: Coca-Cola recipe, Google search algorithm.

Example

- Writing a novel → protected by **Copyright**.
- Inventing a new AI algorithm + device → protected by **Patent**.
- Designing a company logo → protected by **Trademark**.
- Darjeeling tea → protected by **Geographical Indication (GI)**.

Cyber Laws in India: IT Act 2000 Provisions

Cyber Laws in India – IT Act 2000

- The **Information Technology (IT) Act, 2000** is India's **primary cyber law**.
- Enforced from **17th October 2000**.
- Amended in **2008** to strengthen provisions.

Purpose: To give **legal recognition** to e-transactions and define **punishments for cybercrimes**.

Key Provisions of IT Act 2000

1. Legal Recognition of Electronic Records & Signatures

- Digital signatures and e-signatures are legally valid.
- Electronic contracts, emails, and records are acceptable in courts.

Cyber Laws in India: IT Act 2000 Provisions

2. Cybercrimes & Offences

- The Act defines different types of cybercrimes with penalties:
- **Section 43** – Unauthorized access, downloading, virus attacks, DoS attacks.
- **Section 65** – Tampering with computer source code.
- **Section 66** – Hacking, unauthorized access with malicious intent.
- **Section 66C** – Identity theft (stealing password, digital signature).
- **Section 66D** – Cheating by impersonation (phishing, online fraud).
- **Section 66E** – Violation of privacy (capturing/sharing private images).
- **Section 67** – Publishing obscene material online.
- **Section 67B** – Child pornography.
- **Section 72** – Breach of confidentiality and privacy by officials/companies.

Cyber Laws in India: IT Act 2000 Provisions

3. E-Governance Provisions

- Filing applications, forms, and government services electronically.
- Recognition of electronic records in government offices.

4. Cyber Regulations Appellate Tribunal (CRAT)

- Established to handle cybercrime disputes and appeals.

5. Data Protection & Privacy

- Section 43A: Companies must protect **sensitive personal data**.
- If negligence leads to data theft/leak → compensation to affected users.

6. Intermediary Liability

- Platforms (like ISPs, social media, e-commerce websites) must **cooperate with law enforcement**.
- They must remove illegal content when notified.

Cyber Laws in India: IT Act 2000 Provisions

Examples:

- **Hacking** a friend's social media account → punishable under **Section 66**.
- **Phishing email** to steal bank details → **Section 66D**.
- **Sharing obscene videos** online → **Section 67**.
- **Company leaks customer data** → liable under **Section 43A**.

Intellectual Property Law: Copy Right Law

What is Copyright?

- **Copyright = Right to Copy**
- It is a **legal right** that protects the **original works** of creators.
- Gives the creator **exclusive rights** to reproduce, publish, distribute, perform, or adapt their work.

In India: Governed by the **Copyright Act, 1957** (amended in 2012).

What Works are Protected?

- **Literary works** – books, articles, computer programs, databases.
- **Musical works** – songs, compositions.
- **Artistic works** – paintings, drawings, photographs.
- **Dramatic works** – plays, scripts.
- **Cinematographic films** – movies, videos.
- **Sound recordings** – music albums, audiobooks.
- **Software** – treated as “literary work.”

Copy Right Law

Rights of the Copyright Holder

- Reproduce the work.
- Publish/distribute copies.
- Translate or adapt the work.
- Perform/display publicly.
- License or sell rights.

Duration of Copyright

- **Literary, artistic, musical works** → Lifetime of author + 60 years.
- **Films, sound recordings, government works** → 60 years from publication.

Copy Right Law

Infringement of Copyright

- Happens when someone uses a copyrighted work **without permission**.

Examples:

- Pirating movies or songs.
- Copying books/software illegally.
- Uploading someone's work online without credit.

Punishments under Copyright Act (India)

- **Minimum 6 months imprisonment** (can extend up to 3 years).
- **Fine of ₹50,000 to ₹2,00,000.**
- Seizure of infringing copies.

Copy Right Law

Fair Use Exceptions

- Certain uses are **allowed without permission**, such as:
- Education and research.
- Criticism or review.
- Reporting current events.
- Personal/private use.

Example:

- A student downloads a **pirated movie** → Copyright violation.
- A company uses **unlicensed Photoshop** → Violation of Copyright Law.
- A singer's original song is copied without credit → Infringement.

Software License

A **software license** is a **legal agreement** between the software creator/company and the user.

- It defines **how the software can be used, shared, or modified**.
- Without a valid license, using software = **software piracy** (illegal).

In short: A software license is the “permission slip” for using software legally.

“A software license is a legal agreement that defines how software can be used, copied, modified, or shared. It protects developers’ rights and helps users use software legally and safely.”

Why Do We Need Software Licenses?

- To protect **Intellectual Property Rights (IPR)** of developers.
- To prevent **piracy and misuse**.
- To ensure **users know their rights and restrictions**.
- To define whether the software is **free, paid, or open-source**.

Software License

Types of Software Licenses:

1. Proprietary License (Closed Source)

- The most common type.
- User can **use** the software but cannot modify or distribute it.

Example: Microsoft Windows, Adobe Photoshop.

2. Freeware

- Software available **free of cost**, but usually **closed source**.

Example: Google Chrome, Skype.

3. Shareware

- Free to use for a limited period/trial.
- Must pay for full version.

Example: WinRAR, antivirus trial versions.

Software License

4. Open-Source License

- Source code is available to users.
- Can modify, improve, and share.

Example: Linux, Mozilla Firefox.

Popular Open-Source Licenses:

- **GPL (General Public License)** → Must share modified versions freely.
- **MIT License** → Very flexible, allows modification with few restrictions.
- **Apache License** → Allows modification and commercial use.

5. Enterprise / Volume Licensing

- For organizations (multiple users under one license).

Example: Microsoft Office 365 enterprise license.

Software License

Examples for Students

- Installing **pirated Windows OS** → illegal, unsafe.
- Using **Linux Ubuntu** → open-source, free, legal.
- Installing **Photoshop trial version** → shareware, must buy later.
- A company buying **bulk Microsoft Office license** → enterprise licensing.

GDPR

What is GDPR?

- A **European Union (EU) law** that came into effect on **25 May 2018**.
- It protects the **privacy and personal data** of individuals in the EU.
- Even companies outside Europe must follow it if they deal with EU citizens' data.

Key Features:

- **Consent** → Companies must ask permission before collecting personal data.
- **Right to Access** → Users can request to see what data is stored.
- **Right to be Forgotten** → Users can ask for deletion of their data.
- **Data Breach Notification** → Companies must inform users within **72 hours** of a breach.
- **Strict Penalties** → Fines up to **€20 million or 4% of global revenue** (whichever is higher).

GDPR

Example:

- If Facebook or Google collects data of EU citizens without consent → fined under GDPR.
- If an Indian e-commerce company sells products in Europe → must follow GDPR rules.

“GDPR: The General Data Protection Regulation (2018) is an EU law that protects personal data and privacy of individuals, giving them rights like consent, data access, and the right to be forgotten.”

HIPAA

- **HIPAA (Health Insurance Portability and Accountability Act, 1996)**

What is HIPAA?

- A **U.S. federal law** passed in **1996**.
- Main purpose → to **protect sensitive health information** of patients.
- It ensures that medical data (like reports, treatments, health records) is **kept private and secure**.

“HIPAA (1996) is a U.S. law that protects patients’ medical data by ensuring privacy, security, and proper handling of health information in electronic and physical form.”

HIPAA

Key Features of HIPAA:

1. Privacy Rule

- Protects **patients' personal health information (PHI)**.
- Doctors, hospitals, and insurance companies must take **permission before sharing data**.

2. Security Rule

- Requires healthcare providers to use **technical safeguards** (encryption, firewalls, access control) to protect **electronic health records (EHRs)**.

3. Transactions & Code Sets Rule

- Standardizes the **electronic exchange of health information** (billing, insurance claims).

HIPAA

4. Unique Identifiers Rule

- Provides unique ID numbers for healthcare providers, employers, and insurance companies to avoid errors.

5. Enforcement Rule

- Sets penalties for HIPAA violations.

Penalties for Violations

- Fines up to **\$50,000 per violation** (maximum \$1.5 million/year).
- Criminal penalties may include **jail time** if sensitive data is misused.

Examples

- A hospital leaks patient reports online → **HIPAA violation**.
- A nurse shares patient details on social media → **HIPAA violation**.
- Encrypting and securely storing medical records → **HIPAA compliance**.

SOX (Sarbanes–Oxley Act (2002)

Origin: Passed by the U.S. Congress after major corporate scandals like **Enron, WorldCom, Tyco**.

Purpose: To protect investors by improving the accuracy, reliability, and transparency of corporate financial reporting.

➤ It is a **U.S. federal law** that was introduced after big corporate scandals like **Enron and WorldCom**, where companies cheated investors by manipulating financial records.

“SOX is a law that makes companies responsible for the accuracy, security, and transparency of their financial data.”

Purpose:

- To **protect investors** from fraud.
- To ensure **companies keep honest financial records**.
- To improve **trust** in public companies.

SOX

Key Points of SOX:

1. Corporate Responsibility

- Senior executives (like CEO & CFO) must personally certify the accuracy of financial reports.
- If they knowingly falsify, they can face heavy fines or jail.

2. Auditor Independence

- External auditors must be independent, avoiding conflicts of interest.
- Prevents cozy relationships between auditors and companies.

3. Internal Controls (Section 404)

- Companies must implement strong **internal controls** to ensure data integrity.
- Requires yearly audits to check effectiveness of these controls.

SOX

4. Financial Disclosures

- Companies must disclose off-balance-sheet transactions and insider stock trades.

5. Whistleblower Protection

- Protects employees who report fraudulent activities from retaliation.

Importance in Information Security:

- SOX doesn't directly say "use cybersecurity tools," but to comply, companies must ensure:
 - Data accuracy and protection.
 - Audit trails and logging of activities.
 - Secure backup and recovery processes.
 - Restricted access (authentication, RBAC).

Example: If an employee can alter financial records without being tracked, the company violates SOX. That's why **database auditing, logging, and access control** are essential in cybersecurity for SOX compliance.

NIST

National Institute of Standards and Technology

Type: U.S. federal agency under the Department of Commerce.

Role: Develops **standards, guidelines, and best practices** for technology, measurement, and cybersecurity.

Why is NIST Important in Cybersecurity?

- NIST creates frameworks that help organizations **protect their information systems** against cyberattacks.
- It is widely respected globally (not just in the U.S.).

“NIST = U.S. agency that creates trusted cybersecurity standards, frameworks, and encryption methods used worldwide.”

NIST

Key Cybersecurity Contributions of NIST:

1. NIST Cybersecurity Framework (CSF)

- A set of best practices for managing cybersecurity risks.
- Organized into **5 core functions**:
 - **Identify** – Know what assets you need to protect.
 - **Protect** – Implement safeguards (firewalls, access control).
 - **Detect** – Monitor for threats (IDS, SIEM).
 - **Respond** – Take action when an incident happens.
 - **Recover** – Restore systems and data after an attack.

NIST

2. NIST Special Publications (SP 800 series)

- **SP 800-53**: Security and privacy controls for federal systems.
- **SP 800-171**: Protecting sensitive government data in non-federal systems.
- **SP 800-30**: Risk management guide.

3. NIST Standards for Encryption

- Developed widely used algorithms like **AES (Advanced Encryption Standard)** and **SHA (Secure Hash Algorithm)**.

Example:

- Imagine a **bank**:
- **NIST CSF** helps the bank identify sensitive data (like account details), protect it with encryption, detect fraud attempts, respond quickly, and recover customer trust.

ISO27001

Information Security Management System (ISMS)

- **Published by:** International Organization for Standardization (ISO) + International Electrotechnical Commission (IEC)
- **Type:** International Standard
- **Purpose:** Provides a **framework** for managing and protecting **information security** in any organization.

“ISO 27001 is a global rulebook for keeping information safe. It tells organizations *how to set up policies, manage risks, and apply security controls* so that data remains secure and trusted.”

ISO27001

Why is it Important?

ISO 27001 helps organizations:

- Protect **confidentiality, integrity, and availability** (CIA triad) of information.
- Build trust with customers & partners.
- Meet legal, regulatory, and contractual requirements.
- Reduce the risk of data breaches and cyberattacks.

ISO27001

Key Features of ISO 27001:

1. Information Security Management System (ISMS)

- A set of **policies, procedures, and controls** to manage risks.

2. Risk Management

- Identify, assess, and treat risks related to information security.

3. Annex A Controls (114 controls in 14 categories, such as):

- **Access Control** (who can access what).
- **Cryptography** (data protection).
- **Physical Security** (CCTV, server rooms).
- **Operations Security** (monitoring, logging).
- **Compliance** (legal, regulatory).

ISO27001

4. PDCA Cycle (Plan–Do–Check–Act)

- **Plan:** Identify risks and plan controls.
- **Do:** Implement the ISMS.
- **Check:** Monitor, audit, and review.
- **Act:** Improve continuously.

Example

- Suppose a **university** adopts ISO 27001:
- **Plan:** Identify sensitive data (student records, payroll).
- **Do:** Apply encryption, strong passwords, and restricted access.
- **Check:** Audit logs, monitor data access.
- **Act:** Fix weaknesses, train staff, update controls.
- This way, the university keeps data **safe, secure, and compliant**.